

TAREA BRS01

Introducción al bastionado

Autor: Carlos España Del Pozo - CETI

Contenido

Descripción de la tarea.....	3
¿Qué te pedimos que hagas?	3
¿Qué debes hacer?.....	3
Contexto de la organización	3
Respuestas 1	3
Análisis básico de riesgos.	5
Respuestas 2	5
Mediadas de bastionado.	7
Respuestas 3	7
Plan director de seguridad (visión general).....	9
Respuestas 4	9
Reflexión sobre Zero Trust	11
Respuestas 5	11

Descripción de la tarea

¿Qué te pedimos que hagas?

En esta unidad, hemos conocido los fundamentos del bastionado: su origen, necesidad, principales amenazas, y el papel que desempeñan los planes de seguridad dentro de la estrategia de defensa de una organización.

También has aprendido la importancia del análisis de riesgos como punto de partida y has descubierto el nuevo paradigma Zero Trust, que representa una evolución respecto a los modelos clásicos basados en la confianza del perímetro.

Tu tarea consiste en simular la aplicación práctica de estos conceptos en un caso real o inventado, diseñando las bases de un plan inicial de bastionado para una microempresa.

Tu objetivo será analizar su situación actual y proponer medidas básicas de bastionado, apoyándote en los contenidos vistos en esta unidad.

¿Qué debes hacer?

Contexto de la organización

- Describe brevemente la empresa: sector, número de empleados y recursos tecnológicos disponibles.
- Identifica los **tres activos más críticos** y explica por qué lo son para el negocio.

Respuestas 1

La empresa ficticia, es una **PYME de nueva creación** dedicada a ofertar servicios informáticos en Educación. Como empresa orientada a servicios educativos, el principal core de la empresa reside en paginas webs de centros educativos (como puede ser wordpress), servicios webs de plataforma LMS (como puede ser Moodle) y finalmente un servicio de almacenamiento de datos en una nube on-premise.

Para ello, utiliza tanto Tecnologías de la Información (TI) para sus operaciones administrativas y comerciales, como para la implementación de los servicios ofertados a los clientes.

Actualmente cuenta con una plantilla aproximada de catorce personas.

G7			A	B	C
1	Empleados	ROL			
2	1	CEO de la Empresa			
3	1	Director/a de administración y operaciones			
4	1	Director/a de Recursos Humanos			
5	1	Director/a de Marketing			
6	2	Técnicos de Sistemas Junior			
7	1	Técnico de Sistemas Senior			
8	1	Técnico administrador de BBDD			
9	2	Técnico desarrollador de Front			
10	2	Desarrolladores Back (PHP) Junior			
11	1	Desarrollador Back (PHP) Senior			
12	1	Técnico Ciberseguridad			
13	TOTAL	14			
14					
15					

En la empresa, dentro de los activos mas críticos encontraríamos los siguientes:

1. Plataforma LMS y su base de datos

Este activo es fundamental porque contiene datos sensibles de alumnos y profesores (usuarios y contraseñas, calificaciones, materiales didácticos y otra información de interés.) además de ser el servicio mas demandado por los clientes (centros educativos).

Un fallo o pérdida de datos afectaría directamente a los centros educativos, generando un impacto severo en la reputación y en la operatividad de la empresa.

2. Infraestructura de nube on-premise

Todos los servidores, las bases de datos, el almacenamiento (storage físico servido por NFS) y la red que conforma la nube on-premise es crítica porque alberga información y servicios de los clientes.

Si esta infraestructura se ve comprometida (fallo físico, ataque, cifrado por ransomware...), el impacto sería masivo al afectar simultáneamente a los clientes que dependen de ella. Es uno de los servicios mas punteros y por lo tanto core para el negocio.

3. Aplicativo interno de operaciones y facturación

Aunque no sea visible para los clientes, este sistema es clave para la gestión económica y operativa de la empresa: emisión de facturas, control de contratos, gestión del soporte, etc. Si se pierde este servicio, la empresa no podría facturar, gestionar incidencias o mantener un control administrativo adecuado. Un fallo prolongado afectaría directamente a la viabilidad del negocio. (pagos a personal y proveedores)

Análisis básico de riesgos.

- Elabora una **tabla sencilla** donde se reflejen las amenazas y vulnerabilidades más probables, indicando:
 - Impacto potencial
 - Probabilidad de ocurrencia
 - Nivel de riesgo (bajo, medio o alto)
- Señala cuál consideras el **riesgo más crítico** y justifica tu decisión.

Respuestas 2

Esta sería la tabla donde reflejamos muchas de las amenazas y vulnerabilidades que hemos visto en el tema uno:

Amenaza / Vulnerabilidad
Ransomware
Spyware
Troyanos / Gusanos
Bots
Rootkits
Fileless Malware
Fraude / Phishing
Vulnerabilidades sin parchear
Insiders (empleados con acceso)
Ataques externos

Tabla detallada.

Amenaza / Vulnerabilidad		Impacto Potencial	Probabilidad	Nivel de Riesgo
1				
2	Ransomware	Cifrado de datos del LMS, nube on-premise e intranet; parada total de la actividad.	Alta	Alto
3	Spyware	Robo de credenciales de acceso al LMS, o de servidores internos.	Media	Medio-Alto
4	Troyanos / Gusanos	Entrada al sistema, propagación interna y afectación a servidores críticos.	Media	Medio
5	Bots	Caída de las webs, LMS de colegios y servicios cloud.	Media-Alta	Alto
6	Rootkits	Control persistente del atacante y modificación de logs.	Baja-Media	Medio
7	Fileless Malware	Ejecución de código sin dejar rastro en disco.	Media	Medio
8	Fraude / Phishing	Robo de accesos (LMS, facturación, nube), pagos fraudulentos.	Alta	Alto
9	Vulnerabilidades sin parchear	Explotación directa y acceso a servidores internos.	Alta	Alto
10	Insiders (empleados con acceso)	Fuga de datos de RRHH o clientes, borrado de información.	Baja-Media	Medio
11	Ataques externos	Acceso no autorizado a la nube o al LMS.	Alta	Alto

Por otro lado, considero que el riesgo más crítico para los clientes, la empresa y la continuidad del negocio sería el ransomware (aunque lógicamente el resto de riesgos son prácticamente igual de importantes y críticos).

Pero mi decisión se basa en diversas razones:

- Puede impactar directamente en los activos más importantes de la empresa (LMS, Cloud, Aplicaciones internas).
- Un **cifrado masivo** dejaría completamente parada la empresa y a todos sus clientes.
- Su impacto es devastador: pérdida de datos, interrupción del servicio, daños reputacionales y económicos y posible incumplimiento del RGPD si se ven afectados datos sensibles de alumnos o personal.
- La probabilidad es alta, ya que es uno de los ataques más comunes actualmente y la mayoría de las infecciones siguen entrando por correo, phishing o credenciales vulnerables.
- Afecta a toda la infraestructura, no solo a un servicio concreto. Puede cifrar la intranet, servidores internos, bases de datos de RRHH y hasta backups si no están aislados.
- Sin un servicio de Backup correcto y un análisis de incidente para conocer el momento exacto de restauración, sería fatal para la continuación del servicio.

Mediadas de bastionado.

- Propón **al menos cinco medidas concretas** de bastionado adaptadas a la organización. Clasifícalas en:
 - **Medidas técnicas:** configuración segura, actualizaciones, redes, contraseñas, etc.
 - **Medidas organizativas:** políticas, formación, copias de seguridad, gestión de incidentes...
- Justifica brevemente cada medida.

Respuestas 3

A continuación, detallo de manera inicial, las medidas de bastionado propuestas para nuestra PYME:

Medidas técnicas

- Eliminación de cuentas innecesarias

Reduce la posibilidad de accesos no autorizados, especialmente en servidores internos, intranet y plataforma LMS.

- Eliminación de contraseñas por defecto

Evita que un atacante aproveche credenciales conocidas para acceder a la nube on-premise o al aplicativo interno.

- Instalación de firewalls y WAF

El firewall protege la red interna y el WAF protege las webs educativas frente a ataques comunes como inyecciones o escaneos externos.

- Deshabilitación de puertos y servicios no utilizados

Reduce la superficie de ataque de los servidores, evitando que un malware o atacante encuentre puntos débiles expuestos.

- Doble factor de autenticación (2FA) o multifactor de autenticación (MFA)

Minimiza el riesgo de compromiso de credenciales, añadiendo una capa extra de seguridad más allá del usuario/contraseña.

Medidas organizativas

- Implementar políticas de actualizaciones

Mantiene el software protegido frente a vulnerabilidades conocidas que podrían ser explotadas.

- Desarrollar políticas de copia de seguridad y recuperación de sistemas

Permite recuperar datos y servicios críticos (LMS, nube, facturación, RRHH) ante un ataque tipo ransomware o fallo grave.

- Planes de formación y concienciación en seguridad a empleados

Reduce riesgos como phishing, fraude o instalación accidental de malware que puedan comprometer la infraestructura.

- Planes de gestión de incidentes

Define cómo actuar ante ataques o fallos, reduciendo el impacto y el tiempo de recuperación.

- Políticas internas de contraseñas y accesos

Limita privilegios innecesarios y dificulta ataques que dependan del robo o abuso de credenciales.

Plan director de seguridad (visión general).

- Explica cómo estructurarías un **plan director de seguridad** en tu empresa.
- Incluye sus principales apartados: objetivos, alcance, responsables, seguimiento y mejora continua.

Respuestas 4

Para elaborar un **Plan director** en la empresa, lo primero que tendría en cuenta es que debe estar totalmente alineado con el negocio y los servicios ofertados. Es decir, la ciberseguridad debe apoyar a la actividad de la organización y no convertirse en un obstáculo. Además, debe basarse en un análisis de riesgos previo, porque si no sabemos en qué punto estamos, es imposible mejorar.

Dentro del plan director, lo estructuraría en los siguientes apartados:

- **Los objetivos principales serían:**
 - Reducir los riesgos que afectan a los sistemas más críticos (servidores internos, LMS, webs, datos de carácter personal, etc.).
 - Alinear la seguridad con las necesidades del negocio (no poner medidas que bloqueantes).
 - Establecer un marco de trabajo basado en la mejora continua.

El objetivo es llegar a un equilibrio entre la seguridad, la continuidad y la agilidad del servicio.

- **Alcance:**
 - Infraestructura TI de la empresa (servidores internos, nube on-premise, LMS, páginas web, almacenamiento).
 - Puestos de trabajo del personal (14 empleados).
 - Datos críticos de la organización (clientes, alumnos, RRHH, facturación).
 - Redes internas y acceso remoto.

No incluye sistemas externos que no dependan de la empresa.

- **Responsables**

- **Responsable de Seguridad (interno):** coordina el plan, revisa medidas y valida cambios.
- **Equipo Técnico:** aplica las medidas técnicas (actualizaciones, bastionado, redes, etc.).
- **Dirección:** aprueba inversiones y prioriza según impacto en el negocio.
- **Usuarios:** cumplen las políticas y participan en las formaciones.

La idea es que no recaiga todo en una persona, sino que cada rol tenga claro qué parte le corresponde.

- **Seguimiento y control**

El Plan director debe revisarse periódicamente:

- Revisión trimestral del estado de las medidas.
- Incidencias detectadas, cumplimiento de políticas, estado de actualizaciones, etc.
- Informes breves para dirección.

Si una medida no funciona o deja de ser necesaria, se ajusta.

- **Mejora continua**

Como la tecnología y los ataques cambian, el plan no termina nunca. Cada año se revisará:

- Revisar riesgos.
- Actualizar prioridades.
- Añadir nuevas medidas si aparecen amenazas nuevas.
- Evaluar si la empresa ha cambiado (más empleados, más sistemas, nuevos servicios...).

Reflexión sobre Zero Trust

- Indica qué principios del modelo Zero Trust podrían aplicarse a tu empresa y cómo.
- Reflexiona sobre las dificultades prácticas que encontrarías para implantar este modelo en un entorno real de pequeña empresa.

Respuestas 5

Para elaborar una estrategia de Zero Trust en nuestra PYME, nos basaríamos en los siguientes principios que hemos estado viendo en la teoría:

- **MFA/2FA:** exigir doble o multifactor de autenticación para acceder al LMS, la nube on-premise y los sistemas internos, para ello lo implementaríamos tanto en la VPN de acceso como en los diferentes accesos de las aplicaciones.
- **Acceso con mínimos privilegios:** cada usuario solo puede entrar a los servicios que necesite (por ejemplo, RRHH, facturación o LMS). Para ello se establecerán políticas claras, junto a algún modelo de seguimiento recurrente de las mismas mediante revisión semestral.
- **Control del flujo de red:** segmentar la red interna y controlar la comunicación entre servidores, intranet y servicios críticos, además de establecer políticas de red claras en diferentes capas, LAN, WAN, Intranet, etc...
- **Acceso discrecional a aplicaciones:** los usuarios no acceden a toda la red, solo a las aplicaciones que necesitan, para ello utilizaremos medidas con herramientas PAM.

Las dificultades con las que nos vamos a encontrar en una pequeña empresa para implementar las medidas **Zero Trust** serán:

- **Recursos limitados:** implementar MFA, segmentación de red y monitorización puede ser caro o requerir personal especializado.
- **Cambio cultural:** los empleados pueden resistirse a procesos más estrictos de acceso y autenticación.
- **Infraestructura híbrida:** combinar nube, servidores locales y web educativa hace más complejo aplicar reglas estrictas de Zero Trust.
- **Mantenimiento continuo:** Zero Trust requiere revisiones y ajustes constantes, lo que puede ser difícil de gestionar con un equipo pequeño.

En resumen, Zero Trust aporta mucha seguridad, pero su implementación total en una PYME es un reto por costes, personal y complejidad operativa.